TechZeen

AI-DRIVEN CYBER SECURITY

YOUR AI APPLICATION MIGHT LOOK INTELLIGENT, POWERFUL, AND SECURE, BUT JUST ONE VULNERABILITY COULD EXPOSE SENSITIVE DATA, COMPROMISE CONNECTED TOOLS, OR PUT YOUR ENTIRE SYSTEM AT RISK.

TechZeen

WHAT IS OWASP?

OWASP STANDS FOR OPEN WORLDWIDE APPLICATION SECURITY PROJECT. IT IS A GLOBAL NONPROFIT FOUNDATION THAT PROVIDES RESOURCES, GUIDANCE, AND TOOLS TO HELP PEOPLE BUILD MORE SECURE SOFTWARE.

TechZeen

WHAT DOES OWASP TOP 10 MEAN?

IT IS A LIST OF TEN MAJOR SECURITY RISKS THAT DEVELOPERS AND SECURITY PROFESSIONALS SHOULD UNDERSTAND AND ADDRESS. OWASP PUBLISHES DIFFERENT TOP 10 LISTS FOR DIFFERENT AREAS, INCLUDING WEB APPLICATIONS AND LARGE LANGUAGE MODEL (LLM) APPLICATIONS.

TechZeen

THE 10 MOST IMPORTANT AI SECURITY RISKS

TechZeen

LLM01:2026 — PROMPT INJECTION

- MALICIOUS INSTRUCTIONS MANIPULATE AN AI INTO IGNORING ITS INTENDED TASK OR SECURITY BOUNDARIES.
- EXAMPLE: A MALICIOUS EMAIL TRICKS AN AI ASSISTANT INTO ATTEMPTING TO REVEAL PRIVATE INFORMATION.
- PROTECTION: TREAT EXTERNAL CONTENT AS UNTRUSTED AND RESTRICT AI PERMISSIONS.

TechZeen

LLM02:2026 — SENSITIVE INFORMATION DISCLOSURE

- AI APPLICATIONS MAY EXPOSE PRIVATE OR CONFIDENTIAL INFORMATION.
- EXAMPLE: A CHATBOT REVEALS ANOTHER CUSTOMER'S PERSONAL OR FINANCIAL DETAILS.
- PROTECTION: ENFORCE ACCESS CONTROLS, DATA MINIMIZATION, AND PRIVACY SAFEGUARDS.

TechZeen

LLM03:2026 — EXCESSIVE AGENCY

- AN AI AGENT HAS MORE PERMISSIONS OR AUTONOMY THAN IT ACTUALLY NEEDS.
- EXAMPLE: A SUPPORT AGENT CAN DELETE CUSTOMER ACCOUNTS WHEN IT ONLY NEEDS TO ANSWER QUESTIONS.
- PROTECTION: APPLY LEAST PRIVILEGE AND REQUIRE APPROVAL FOR SENSITIVE ACTIONS.

TechZeen

LLM04:2026 — SUPPLY CHAIN

- THIRD-PARTY MODELS, DATASETS, LIBRARIES, AND SERVICES MAY INTRODUCE SECURITY RISKS.
- EXAMPLE: AN APPLICATION USES A COMPROMISED AI MODEL DOWNLOADED FROM AN UNTRUSTED SOURCE.
- PROTECTION: VERIFY SOURCES, SCAN DEPENDENCIES, AND MONITOR THIRD-PARTY COMPONENTS.

TechZeen

LLM05:2026 — DATA AND MODEL POISONING

- ATTACKERS MANIPULATE TRAINING, FINE-TUNING, OR OTHER DATA USED TO DEVELOP OR OPERATE AI SYSTEMS.
- EXAMPLE: POISONED TRAINING EXAMPLES TEACH A MODEL TO PRODUCE HARMFUL OR MISLEADING RESPONSES.
- PROTECTION: VALIDATE DATASETS, CONTROL ACCESS, AND MONITOR MODEL BEHAVIOR.

TechZeen

LLM06:2026 — UNBOUNDED CONSUMPTION

- EXCESSIVE OR ABUSIVE REQUESTS CONSUME RESOURCES, INCREASE COSTS, OR MAKE AN AI SERVICE UNAVAILABLE.
- EXAMPLE: AN ATTACKER SENDS THOUSANDS OF EXPENSIVE REQUESTS TO AN AI APPLICATION.
- PROTECTION: SET RATE LIMITS, USAGE QUOTAS, TOKEN LIMITS, AND SPENDING ALERTS.

TechZeen

LLM07:2026 — MISINFORMATION

- AI GENERATES FALSE OR MISLEADING INFORMATION THAT USERS MAY TRUST.
- EXAMPLE: A SECURITY ASSISTANT INVENTS A CVE DETAIL AND RECOMMENDS THE WRONG FIX.
- PROTECTION: VERIFY IMPORTANT CLAIMS, USE RELIABLE SOURCES, AND COMMUNICATE UNCERTAINTY.

TechZeen

LLM08:2026 — HIDDEN CONTEXT EXPOSURE

- SENSITIVE INFORMATION FROM AN AI SYSTEM'S INTERNAL CONTEXT OR PROCESSING MAY BE EXPOSED UNINTENTIONALLY.
- EXAMPLE: PRIVATE INSTRUCTIONS OR CONFIDENTIAL CONTEXT APPEAR IN AN AI RESPONSE OR OUTPUT.
- PROTECTION: KEEP SECRETS OUT OF PROMPTS, ISOLATE SENSITIVE CONTEXT, AND CONTROL WHAT THE MODEL CAN REVEAL.

TechZeen

LLM09:2026 — VECTOR AND EMBEDDING WEAKNESSES

- WEAKNESSES IN AI SEARCH SYSTEMS CAN ALLOW MANIPULATED DATA, INCORRECT RETRIEVAL, OR UNAUTHORIZED INFORMATION ACCESS.
- EXAMPLE: A RAG CHATBOT RETRIEVES CONFIDENTIAL DOCUMENTS FOR A USER WHO LACKS PERMISSION TO VIEW THEM.
- PROTECTION: ENFORCE DOCUMENT-LEVEL ACCESS CONTROLS, VALIDATE DATA SOURCES, AND SECURE VECTOR DATABASES.

TechZeen

LLM10:2026 — IMPROPER OUTPUT HANDLING

- AN APPLICATION USES AI-GENERATED OUTPUT WITHOUT PROPERLY VALIDATING OR SAFELY PROCESSING IT.
- EXAMPLE: A WEBSITE DISPLAYS AI-GENERATED HTML WITHOUT SANITIZATION, POTENTIALLY ENABLING CROSS-SITE SCRIPTING (XSS).
- PROTECTION: VALIDATE OUTPUTS, SANITIZE CONTENT, AND SAFELY HANDLE GENERATED CODE OR COMMANDS.